

Nhóm 6 - Lỗ hổng Ứng dụng Web (Web Vulnerabilities)

Phân loại rủi ro	20 lỗi vi phạm
Injection & Dữ liệu	1. Form đăng nhập hệ thống dính SQL Injection. 2. Bình luận khóa học MOOC dính Stored XSS. 3. Sửa ID trên URL để xem điểm của nhóm khác (IDOR). 4. Module minh chứng cho phép upload file PHP. 5. Đường dẫn file dính Directory Traversal. 6. Không có mã Token chống CSRF. 7. Hiện thị chi tiết mã lỗi truy vấn SQL ra màn hình người dùng.
Xác thực & API	8. API lộ thông tin cá nhân của giảng viên. 9. Không giới hạn số lần nhập sai mật khẩu (Brute-force). 10. Để lộ mật khẩu kết nối Database trong file HTML. 11. Lộ cấu trúc thư mục Git ra môi trường web. 12. Cấu hình CORS lỏng lẻo cho phép mọi domain gọi API. 13. Dùng thư viện JavaScript cũ dính lỗ hổng. 14. Mã JWT Token sinh ra không được mã hóa an toàn.
Logic & Cấu hình	15. Bật chế độ Debug hiển thị lỗi trên server thật. 16. Thiếu các HTTP Security Headers cơ bản. 17. Truyền Session ID lộ liễu trên thanh URL. 18. Không tự động thu hồi Cookie khi đăng xuất. 19. Bỏ qua bước kiểm duyệt đề tài của trường bộ môn bằng cách sửa tham số. 20. Chỉ xác thực dữ liệu đầu vào bằng JavaScript ở client thay vì backend.